# ROAD TO HALL OF FAME

ACTIVIDAD 12

## File path traversal, validation of file extensión with null byte bypass

Reporte técnico del laboratorio académico de PortSwigger Web Security Academy. La práctica se realizó dentro de un entorno autorizado para analizar una vulnerabilidad de path traversal en el endpoint encargado de mostrar imágenes de producto.

| | |
|---|---|
| Asignatura | CNO IV - Seguridad Informática |
| Parcial | 02 |
| Actividad | 12 |
| Categoría | Path Traversal |
| Herramienta principal | Burp Suite - Proxy / HTTP history / Repeater |
| Plataforma | PortSwigger Web Security Academy |
| Estado | Solved |

BRUNO LUNA - PACLONK D. MEI
UPSLP // 2026

# 01 // CONTEXTO Y OBJETIVO

El laboratorio presenta una vulnerabilidad de file path traversal en la funcionalidad que muestra imágenes de producto. La aplicación valida que el nombre de archivo recibido termine con la extensión esperada. El objetivo consiste en recuperar el contenido del archivo /etc/passwd.

En nuestra instancia observamos solicitudes al endpoint /image con archivos .jpg. La restricción de extensión impide que una ruta de traversal simple funcione de forma directa, por lo que necesitamos conservar una terminación que cumpla la validación y, al mismo tiempo, lograr que el backend interprete como destino real el archivo del sistema.

Nota de documentación: en los puntos donde aparece la representación codificada utilizada para el terminador nulo, mantenemos el marcador ../../../etc/passwd%00.png, siguiendo la convención del portafolio.

## Procedimiento aplicado

1. Usamos Burp Suite para identificar una solicitud que obtiene una imagen de producto y confirmamos que el parámetro filename controla el nombre del archivo solicitado.

2. Enviamos la petición a Repeater y sustituimos el valor original por una ruta de traversal que apunta a /etc/passwd. Después del archivo objetivo agregamos ../../../etc/passwd%00.png y conservamos una terminación .jpg.

3. Reenviamos la petición y verificamos que la respuesta HTTP contiene las entradas del archivo /etc/passwd. Finalmente, PortSwigger marca el laboratorio como Solved.

## Solicitud documentada

```
GET /image?filename=../../../etc/passwdAQUI VA EL ENCODE.jpg HTTP/1.1
```

La solución oficial de PortSwigger explica el mismo principio: mantener una extensión aceptada por la aplicación mientras se introduce un terminador nulo para que el procesamiento posterior de la ruta no coincida con la validación hecha sobre la cadena completa.

# 02 // EVIDENCIA 01 - IDENTIFICACIÓN DE LA PETICION

En Proxy - HTTP history localizamos varias solicitudes GET al endpoint /image. Seleccionamos una de ellas para confirmar la estructura normal del parámetro filename. La captura muestra una solicitud con un archivo .jpg, lo que nos sirve como referencia antes de modificar la petición en Repeater.

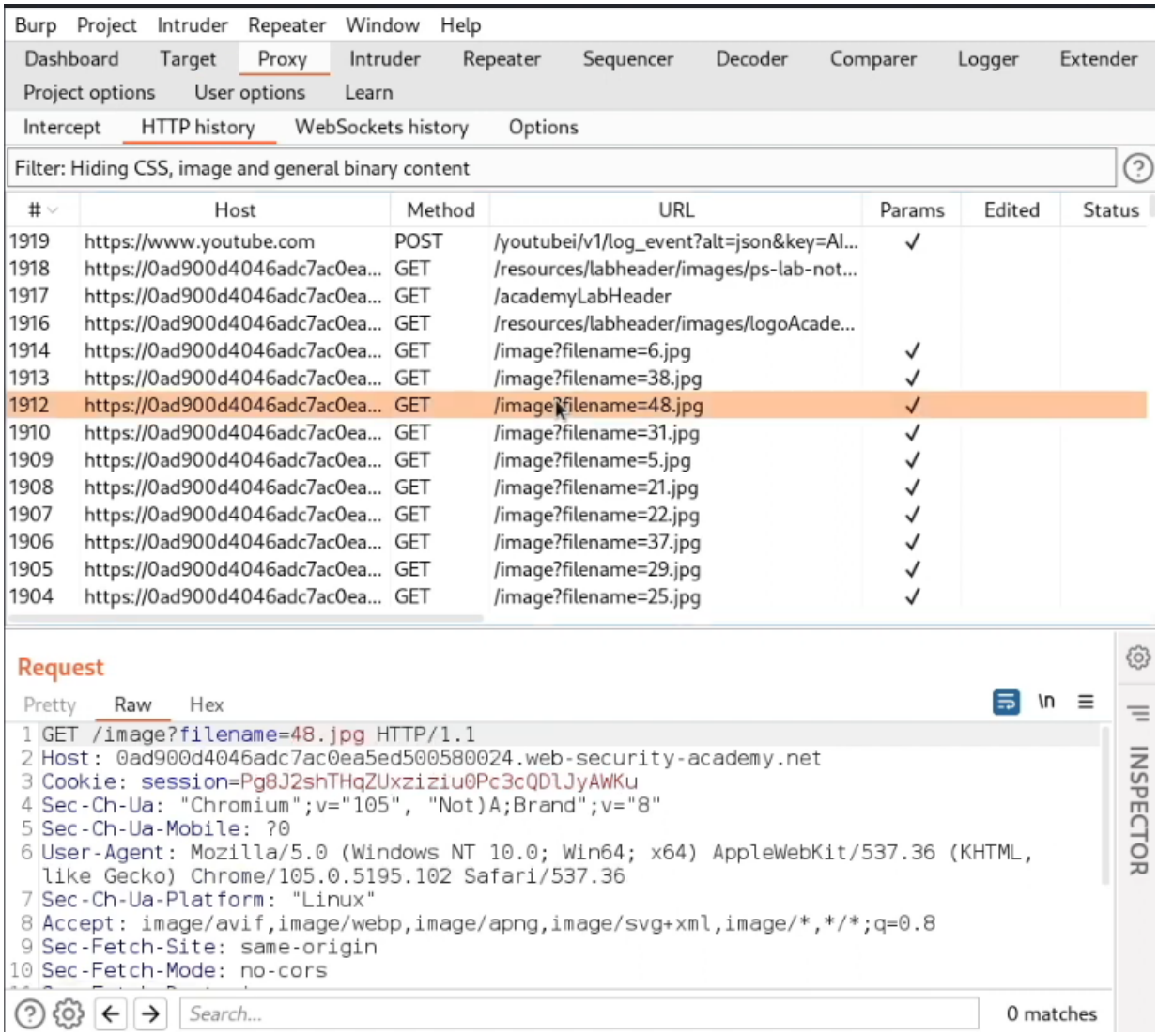



Figura 1. HTTP history de Burp Suite mostrando una solicitud de imagen controlada mediante el parámetro filename.

# 03 // EVIDENCIA 02 - BYPASS Y LECTURA DEL ARCHIVO

En Repeater modificamos el parámetro filename para apuntar al archivo objetivo mediante secuencias de traversal. A continuación dejamos el marcador AQUI VA EL ENCODE antes de la extensión .jpg. La respuesta devuelve HTTP/1.1 200 OK y muestra entradas correspondientes a /etc/passwd, incluyendo usuarios del sistema como root, daemon y otros.

Este resultado demuestra que la comprobacion de la extensión no representa una protección suficiente cuando existe una diferencia entre la cadena validada por la aplicación y la forma en que una capa posterior interpreta el nombre del archivo.

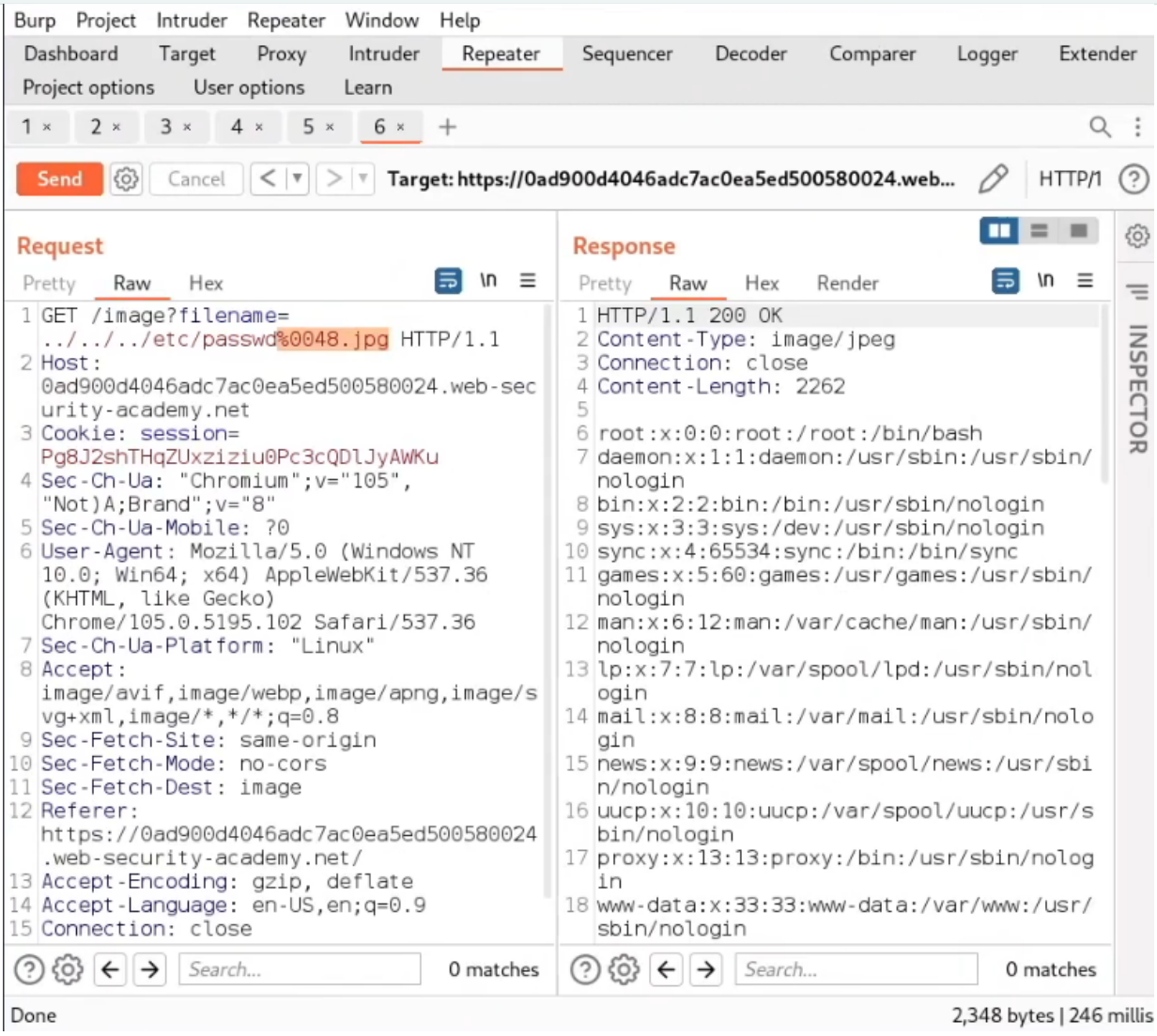



Figura 2. Burp Repeater mostrando la solicitud modificada y el contenido de /etc/passwd en la respuesta.

# 04 // EVIDENCIA 03 - VALIDACIÓN FINAL

Después de recuperar correctamente el archivo requerido, la plataforma reconoce la condición del ejercicio y muestra el estado Solved. Esta captura constituye la evidencia final de que completamos la Actividad 12 dentro del entorno de práctica autorizado de PortSwigger Web Security Academy.

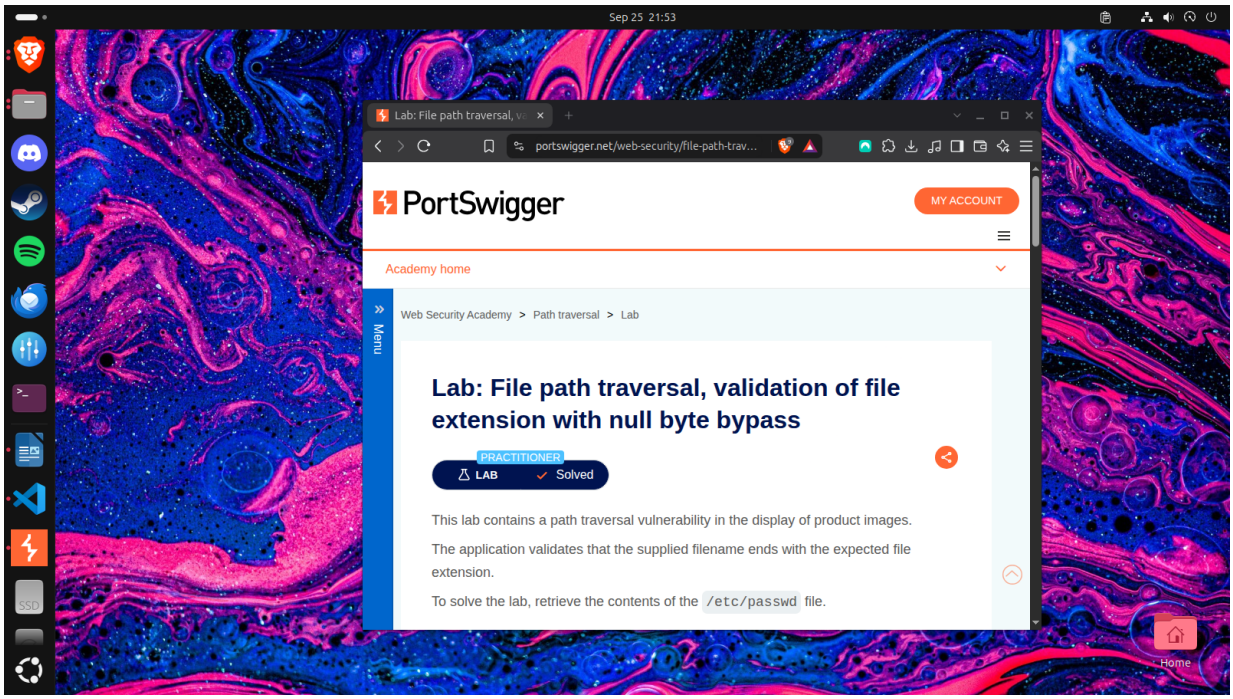



Figura 3. Página del laboratorio mostrando el estado Solved.

# 05 // ANÁLISIS TÉCNICO

| | |
|---|---|
| Validación insuficiente | La aplicación comprueba la terminación del nombre de archivo, pero esa validación no garantiza que el recurso finalmente procesado pertenezca al conjunto permitido. |
| Diferencia de interpretación | El bypass aparece cuando distintas capas procesan la misma cadena de forma diferente. Una capa valida el sufijo visible y otra puede considerar terminada la ruta antes de esa extensión. |
| Impacto | La lectura arbitraria de archivos puede exponer configuraciones, credenciales, información del sistema y otros datos accesibles para el proceso web. |
| Mitigación | La aplicación no debe construir rutas directamente con entrada controlada por el usuario. Conviene trabajar con identificadores permitidos, canonicalizar la ruta final y comprobar que el destino permanezca dentro de un directorio autorizado. |

## Conclusión

Con este laboratorio comprobamos que validar solamente la extensión de un archivo no elimina una vulnerabilidad de path traversal. La seguridad depende de cómo se resuelve y valida la ruta completa antes de acceder al sistema de archivos. Al trabajar con Burp Suite pudimos observar el comportamiento normal, modificar la entrada de forma controlada y comparar directamente la solicitud con la respuesta obtenida.

La práctica también refuerza la importancia de analizar las transformaciones que ocurren entre la entrada HTTP y la operación final del backend, ya que una comprobacion aparentemente correcta puede fallar si otra capa interpreta la misma cadena de manera diferente.

## Fuente consultada

PortSwigger Web Security Academy. Lab: File path traversal, validation of file extensión with null byte bypass. https://portswigger.net/web-security/file-path-traversal/lab-validate-file-extensión-null-byte-bypass